

Security+ 1.2 · Physical Security

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2** —
Physical Security (8:17) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Physical security controls protect data centers and offices. Preventive measures include guard shacks, bollards, fences, badge/RFID/NFC readers, and mantraps/vestibules to prevent piggybacking. HVAC and fire suppression protect infrastructure, while cameras and alarms provide detection.

High-Yield Core Concepts Tested on Exam

- Mantrap/vestibule: two doors, one opens only when the other closes — prevents tailgating
- Fire suppression: clean agent (FM-200) is preferred over water in data centers
- Hot/cold aisle + HVAC = controlled temperature
- Badge/RFID/NFC readers control access
- Bollards, fences, and guard shacks are preventive physical controls

Exam Tips & Classic Scenarios

- 'Prevents tailgating/piggybacking' = mantrap / vestibule control
- 'Fire suppression agent that doesn't damage equipment' = FM-200/clean agent
- Physical security is often tested with scenario-based questions about unauthorized entry
- Remember: preventive controls stop access; detective controls (cameras, alarms) record it

Typical Exam Scenario: A company prevents an unauthorized person from following an employee into the server room by using a mantrap/vestibule. This is an example of physical security control against tailgating.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — Physical Security)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Credential cloning
- D)** Dumpster diving

2. Decoy system that pretends to be vulnerable to attract and study attackers:

- A) Honeypot**
- B) DMZ**
- C) Bastion host**
- D) Jump box**

3. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators with generic credentials**
- D) Implement the corresponding solution: Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating**

4. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Fire suppression: clean agent (FM-200) > water in datacenter'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Fire suppression: clean agent (FM-200) > water in datacenter...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

5. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Hot/cold aisle + HVAC = controlled temperature'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Hot/cold aisle + HVAC = controlled temperature.**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'prevents tailgating/piggybacking' = mantrap / vestibule control. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'prevents tailgating/piggybacking' = mantrap / vestibule control.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Typical scenario: 'company prevents a person from entering the server room behind another' → mantrap/vestibule.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Typical scenario: 'company prevents a person from entering the server room behind another'...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Physical Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Fire suppression: clean agent (FM-200) > water in datacenter'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Fire suppression: clean agent (FM-200) > water in datacenter...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

2) A — Honeypot.

✓ **Why it is correct:** A honeypot is a decoy system designed to appear vulnerable and attract attackers, with the goal of studying their tactics, techniques, and procedures (TTPs), diverting attention from real systems, and gathering threat intelligence. It can be low-interaction (simulates services) or high-interaction (isolated real system). It is a proactive security and detection control, per SY0-701 objectives 3.2 (security implementation) and 4.8 (monitoring and detection). The question describes exactly a decoy system that pretends to be vulnerable to attract and study attackers, which is the definition of a honeypot.

✗ **Why the others are wrong:**

- *DMZ:* A DMZ (Demilitarized Zone) is a physical or logical subnetwork that sits between the trusted internal network and the untrusted external network (e.g., the Internet). It hosts public services (web, email, DNS) to prevent external attacks from directly reaching the internal network. A DMZ is not a decoy system; it is a network segment designed to expose services in a controlled manner. It does not pretend to be vulnerable nor aims to attract and study attackers. The question asks for a decoy system, not a segmentation architecture.
- *Bastion host:* A bastion host is a heavily protected system exposed to an untrusted network, typically acting as a single entry point for remote administration or as a proxy. It is hardened and monitored, but it is not a decoy; it is a defense point. Its purpose is to be secure, not to appear vulnerable. The question describes a system that pretends to be vulnerable to attract attackers, which is the opposite of a bastion host, which is designed to be as secure as possible.
- *Jump box:* A jump box (or jump server) is an intermediary system used to access and administer devices in a segregated network, such as a DMZ or internal network. It centralizes administrative access, enforces strong authentication, and logs activities. It is not a decoy; it is an access control tool. It does not pretend to be vulnerable nor aims to study attackers. The question asks for a decoy system, not an administrative jump point.

3) D — Implement the corresponding solution: Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating. This is a physical access control that mitigates unauthorized entry by ensuring individuals cannot bypass authentication.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Fire suppression: clean agent (FM-200) > water in datacenter....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): Fire suppression: clean agent (FM-200) > water in datacenter. FM-200 is a clean agent fire suppression system that is safe for use in data centers because it does not leave residue and is electrically non-conductive, unlike water which can cause significant damage to electronic equipment. Therefore, implementing FM-200 is the best recommendation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: Hot/cold aisle + HVAC = controlled temperature..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): Hot/cold aisle + HVAC = controlled temperature. This is a physical security control to maintain optimal environmental conditions for equipment; the appropriate control is to implement the corresponding solution, such as hot/cold aisle containment and HVAC systems.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

6) A — Implement the corresponding solution: 'prevents tailgating/piggybacking' = mantrap / vestibule control..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): 'prevents tailgating/piggybacking' = mantrap / vestibule control. A mantrap (access control vestibule) is a physical security control that allows only one person at a time to enter, preventing unauthorized individuals from following an authorized person.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent. FM-200 (heptafluoropropane) is a clean agent fire suppressant that extinguishes fires without leaving residue or damaging electronic equipment, unlike water or foam.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Typical scenario: 'company prevents a person from entering the server room behind another'....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): Typical scenario: 'company prevents a person from entering the server room behind another' → mantrap/vestibule. A mantrap (or access vestibule) is a physical security control that uses two interlocking doors to prevent tailgating, ensuring that only one person can pass through at a time after proper authentication.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the

Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

9) B — Implement the corresponding solution: Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Physical Security): Mantrap/vestibule: 2 doors, only one opens when the other closes — prevents tailgating. A mantrap is a physical preventive control that enforces one-person-at-a-time entry, mitigating tailgating and unauthorized physical access.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Fire suppression: clean agent (FM-200) > water in datacenter....

✓ **Why it is correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 1.2 (Physical Security): Fire suppression: clean agent (FM-200) > water in datacenter. Clean agents like FM-200 suppress fires without leaving residue or damaging electronic equipment, unlike water which can cause catastrophic damage to IT infrastructure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

